CC8130
Segurança na Informação

O Processo de Desenvolvimento de Segurança Preventiva

centro universitário FEI

Prof. Dr. LeonardoAnjoletto Ferreira

2º Semestre de 2024

Segurança.....

- Entediante
- Desativador de funcionalidades
- Difícil de medir
- Habilidade?
- Criar algo novo?

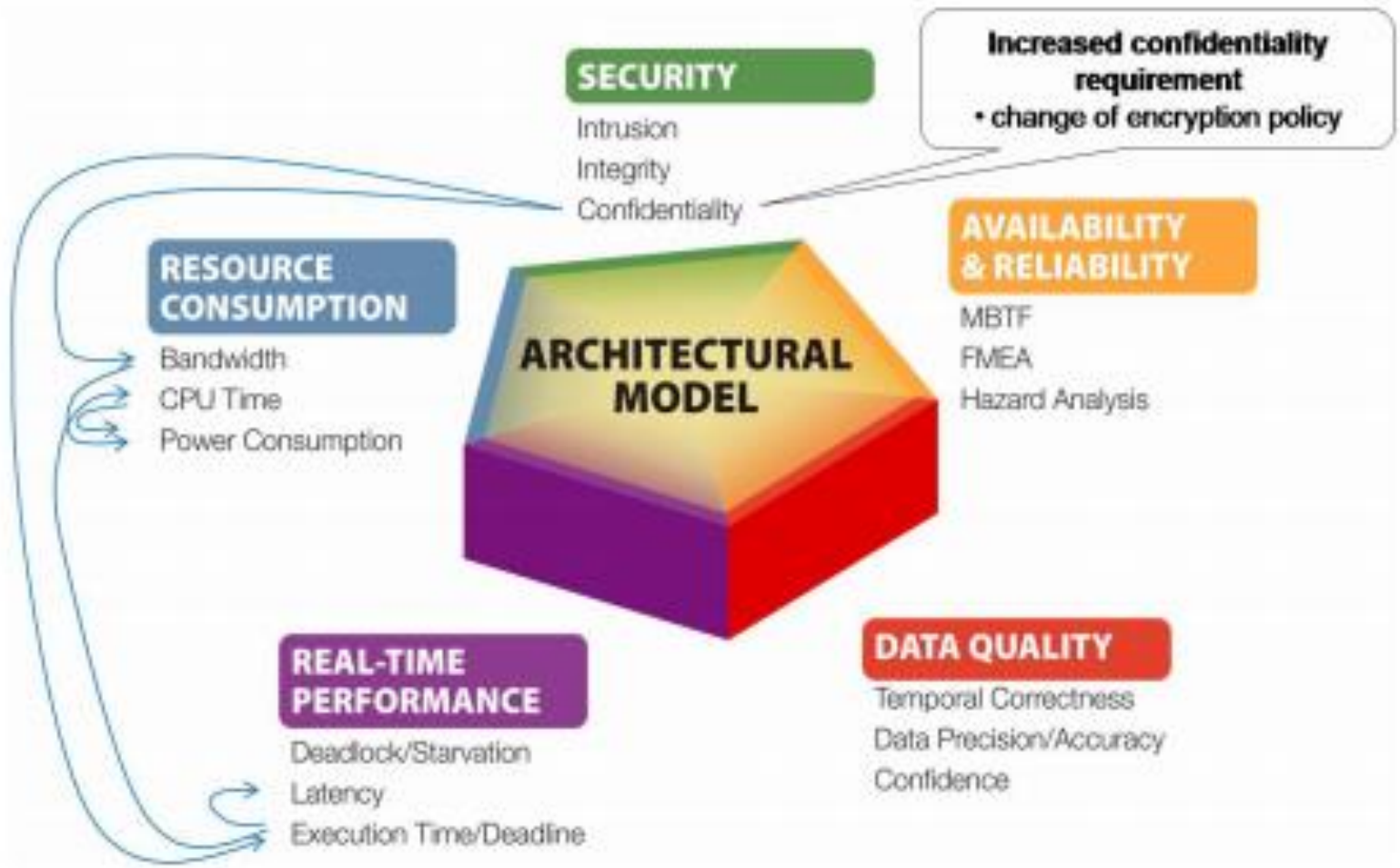
Pessoas optam por não construir sistemas seguros

Ou

Pessoas cometem equívocos

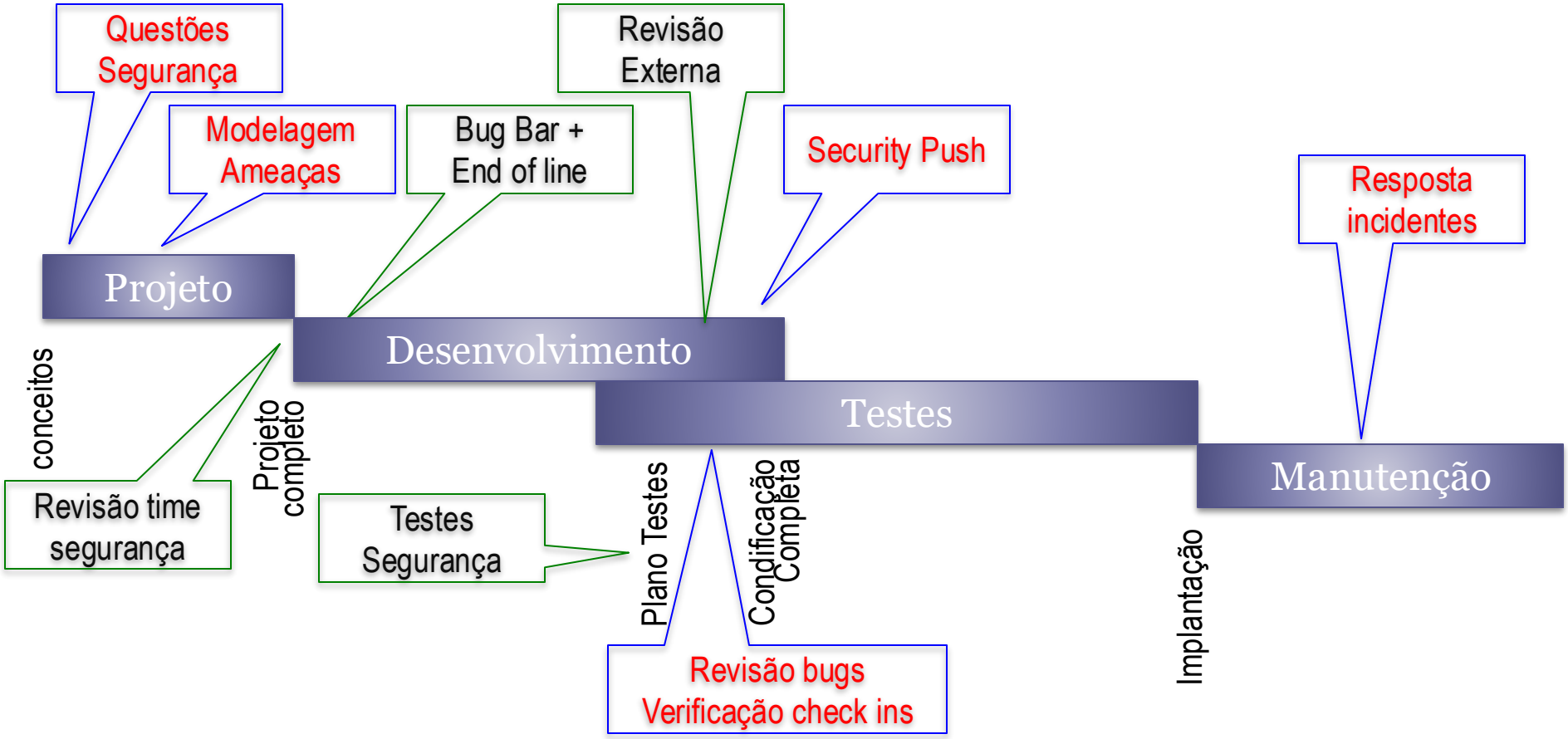
centro universitário FEI

Segurança.....



centro universitário FEI

Melhorias incrementais da segurança



centro universitário FEI

Questões de segurança do produto

- Quem é o público alvo?
- O que a segurança significa para este grupo?
- Onde o aplicativo será executado
- O que deve ser protegido?
- Quais as implicações do comprometimento das informações?
- Quem vai gerenciar o aplicativo?
- Quais as necessidades de comunicação do produto?
- Qual a infra-estrututra disponível?

centro universitário FEI

Requisitos típicos de....

- Confidencialidade
- Integridade
- Disponibilidade
- Autenticação
- Autorização
- Auditoria e Logging
- Tratamento de Exceção e erros

centro universitário FEI

Autenticação x Autorização

Authorization

What you can do

Authentication

Who you are

centro universitário FEI

O que importa?

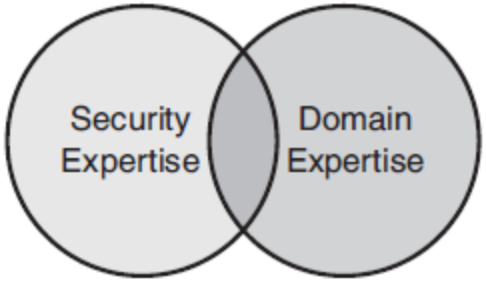
Recursos de Segurança $\neq$ Recursos Seguros

O que importa?

centro universitário FEI

Ampliando as capacidades

- Pouca integração entre as equipes
- Risco do investimento em retorno



- Conhecimento disseminado
- Otimização dos recursos
- Minimização dos riscos

PROJETO

- Tempo para segurança
- Modelar as ameaças
- Plano de FIM do ciclo de vida
- Ajustando a barra de bugs
- Equipe de Segurança

centro universitário FEI

Bug Bar?

Não é novo, aliás, é um conceito bem antigo

https://docs.microsoft.com/en-us/previous-versions/windows/desktop/cc307404(v=msdn.10)#EBAA

Denial of Service (Server) Matrix

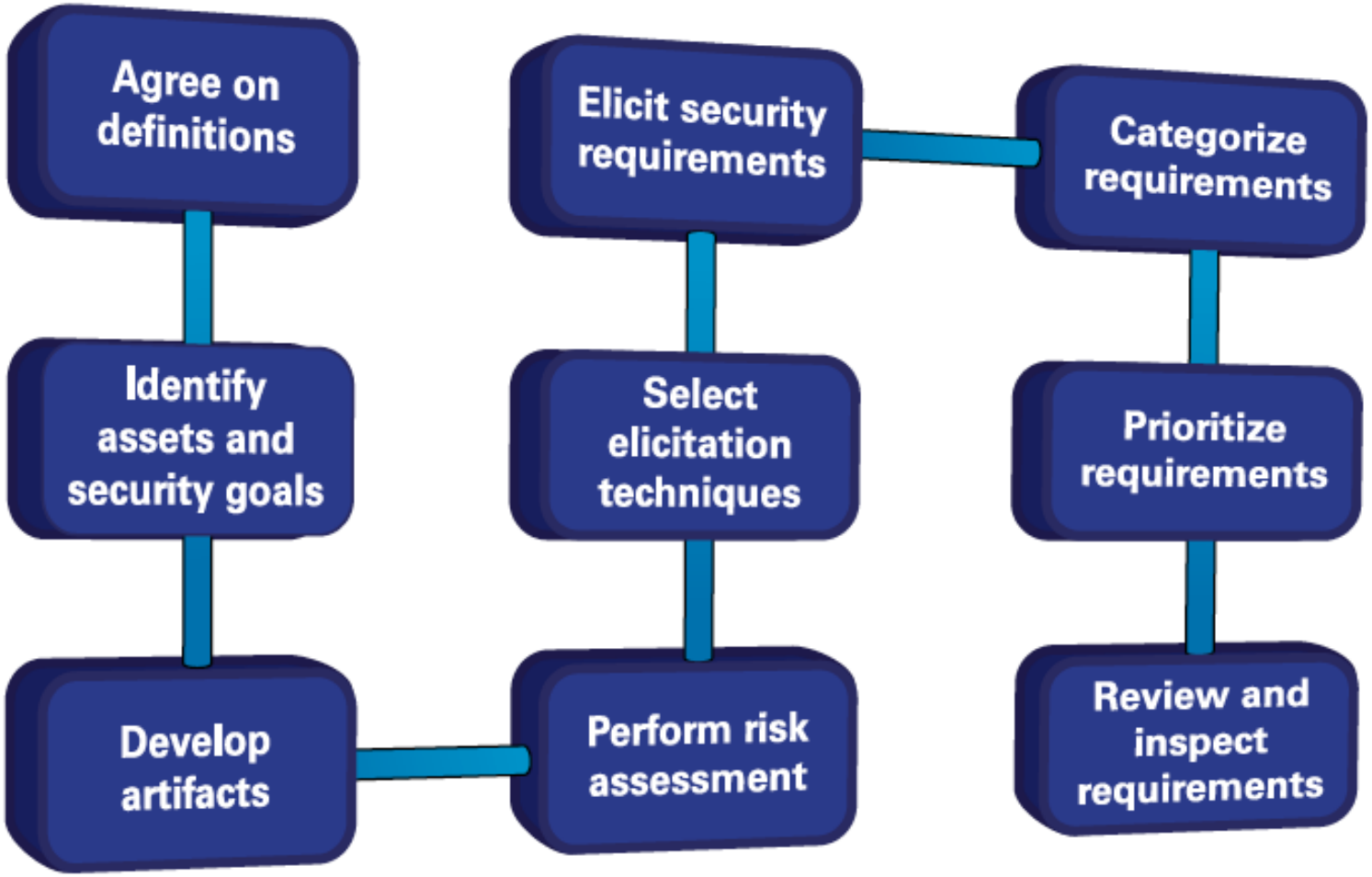
Authenticated vs. Anonymous attack	Default/Common vs. Scenario	Temporary DoS vs. Permanent	Rating
Authenticated	Default/Common	Permanent	Moderate
Authenticated	Default/Common	Temporary DoS with amplification	Moderate
Authenticated	Default/Common	Temporary DoS	Low
Authenticated	Scenario	Permanent	Moderate
Authenticated	Scenario	Temporary DoS with amplification	Low
Authenticated	Scenario	Temporary DoS	Low
Anonymous	Default/Common	Permanent	Important
Anonymous	Default/Common	Temporary DoS with amplification	Important
Anonymous	Default/Common	Temporary DoS	Moderate
Anonymous	Scenario	Permanent	Important
Anonymous	Scenario	Temporary DoS with amplification	Important
Anonymous	Scenario	Temporary DoS	Low

Mas MUITO útil na priorização....

centro universitário FEI

SQUARE

Security Quality Requirements Engineering



centro universitário FEI

Desenvolvimento

- Check-in de novo código
  - Quem faz?
  - Quem revisa?
- Diretrizes de codificação segura
- Revisar falhas antigas
- Revisão externa da segurança
- Bugs: Contagem e métricas
- Easter eggs!

centro universitário FEI

Testes

centro universitário FEI

Manutenção e Distribuição

- Terminou?
- Como responder?
- Responsáveis

centro universitário FEI

Requisitos típicos de....

- Confidencialidade
  - Senha e outros campos de entrada de dados sensíveis necessitam ser mascarados.
  - Senhas não devem ser armazenadas as claras nos sistemas backend, e quando armazenadas devem passar por processo de hash com uma função pelo menos equivalente a SHA-256.
  - Transport Layer Security (TLS) como Secure Socket Layer (SSL) deve ser colocado em prática para proteger contra ameaças internas de Man in the Middle (MITM) para todas as informações de cartão de crédito que seja transmitida.
  - O uso de protocolos reconhecidamente inseguros como, por exemplo, File Transfer Protocol (FTP) para transmitir credenciais de contas em texto claro a terceiros fora de sua organização deve ser proibido.
  - Arquivos de log não devem armazenar qualquer informação sensível como definido pelo negócio, de modo que seja compreensível por seres humanos.

Requisitos típicos de....

- Integridade
  - Todos os formulários de entrada e query strings necessitam ser validadas frente a um conjunto de entradas aceitáveis, antes do software aceita-los para processamento.
  - O software a ser publicado deve ser disponibilizado juntamente com o checksum e a função hash usada pra computar o checksum, de modo que o interessado possa validar sua precisão e completude.
  - Todos os atores não humanos (um outro sistema ou processos batch) devem ser identificados, monitorados e impedidos de alteração de dados, a medida que ele passa no sistema que eles rodam, a não ser que explicitamente autorizado para tal.

Requisitos típicos de....

- Disponibilidade
  - O software deve oferecer alta disponibilidade de oito (8) noves (9), como definido pelo SLA.
  - O software deve estar preparado para atender capacidade máxima de 300 usuários simultâneos.
  - O software e seus dados devem ser replicados por todos os centros de dados para prover balanceamento de carga e redundância.
  - A funcionalidade de missão crítica no software deve ser restaurada a operação normal no prazo de 1 hora de descontinuidade; funcionalidade de missão essencial no software deve ser restaurada a operação normal no prazo de 4 horas da interrupção, e funcionalidade de missão suporte no software deve ser restaurada a operação normal no prazo de 24 horas.

Requisitos típicos de....

- Autenticação
  - O software será implantado somente na Intranet e o usuário autenticado deve fornecer novamente suas credenciais para acessar a aplicação, uma vez que esteja autenticado na rede.
  - O software deverá suportar single sign on a terceiros e fornecedores que estão definidos na lista de interessados.
  - A política de autenticação garante a necessidade para dois – ou autenticação com múltiplos fatores para todos os softwares de processamento financeiro.

Requisitos típicos de....

- Autorização
  - O acesso a arquivos secretos de alta sensibilidade deve ser restrito somente a usuários com níveis de permissão secreto e super-secreto.
  - Os usuários não devem ser demandados a enviar suas credenciais sempre, uma vez que ele tenha se autenticado com sucesso.
  - Todos os usuários autenticados herdarão a permissão de leitura somente que são parte do papel do usuário convidado enquanto os usuários autenticados por padrão terão permissão de leitura e escrita como parte do papel de usuário regular. Somente os usuários com acesso administrativo, terão todos os direitos dos usuários regulares, adicionalmente a execução de operações.

Requisitos típicos de....

- Auditoria e Logging
  - Todas as tentativas de logon devem ser registradas juntamente com o timestamp e o endereço de IP de origem da requisição.
  - Os valores anterior e posterior a uma mudança de preço modificado por um usuário, quando da atualização de um preço por um usuário, devem ser monitorados com os seguintes campos auditados: identidade, ação, objeto e timestamp.
  - Os logs de auditoria devem sempre ser adicionados de novos registros e nunca sobrescritos.
  - Os logs de auditoria devem ser mantidos de forma segura por um período de 3 anos.
  - Gerenciamento de Sessão
  - Cada atividade do usuário deverá ser rastreada de modo único.
  - O software não deve solicitar as credenciais de acesso do usuário, uma vez que ele esteja autenticado no Internet Banking.
  - As sessões devem ser explicitamente suspensas quando o usuário solicita o log off ou fecha a janela do browser.
  - Identificadores de sessão usados para identificar a sessão de usuários devem não ser passados em claro ou ser facilmente adivinhado.

centro universitário FEI

Requisitos típicos de....

- Gerenciamento de exceção e erros
  - Todos os erros e exceções devem ser explicitamente manipulados a partir de blocos try, catch e finally.
  - Mensagens de erro que são mostradas ao usuário revelarão somente a informação necessária, sem vazamento de detalhes internos do sistema na mensagem de erro.
  - Detalhes de exceções de segurança devem ser auditados e monitorados periodicamente.
  - Parâmetros de Configuração
  - Os dados sensíveis do arquivo de configuração da aplicação web, como strings de conexão, devem ser encriptados .
  - Senhas e chaves de criptografia não devem ser registradas no código fonte do software.
  - A inicialização e a liberação de variáveis globais necessitam ser monitoradas com muito cuidado.
  - Eventos de inicialização e interrupção de sessão devem incluir proteções na informação de configuração como uma salvaguarda contra ameaças de vazamento.